

一、API 基本資訊

- 路由端點 (Endpoint): /cgi-bin/update_member_role.py
- 請求方法 (HTTP Method): POST
- 內容類型 (Content-Type): application/json; charset=utf-8

二、請求參數規範 (Request Payload)

前端進行任何權限異動操作時，必須發送以下格式的 JSON 封包：

```
JSON
{
  "payload": {
    "family_id": 12
    "admin_uid": "admin_001"
    "target_uid": "target_user_99"
    "target_role": "Guest"
    "start_time": "2026-06-04 00:00:00"
    "end_time": "2026-06-05 23:59:59"
    "max_uses": 3
  }
}
```

欄位詳細說明

欄位名稱	型態	必填	說明
family_id	Integer	是	目標家庭場域的唯一流水號 ID。
admin_uid	String	是	執行此操作之屋主的帳號(必須為該場域的 Admin)。
target_uid	String	是	被操作的目標成員帳號。

target_role	String	是	預期變更的目標角色, 僅允許: Admin, Member, Guest, Technician, SP, Revoked。
start_time	String	否/可為 null	臨時權限生效時間 (格式: YYYY-MM-DD HH:MM:SS)。常駐成員請帶 null 。
end_time	String	否/可為 null	臨時權限截止時間 (格式: YYYY-MM-DD HH:MM:SS)。常駐成員請帶 null 。
max_uses	Integer	否/可為 null	最大允許成功操作 (開門) 次數。不限制次數請帶 null 。

三、後端核心業務邏輯與驗證流程

CGI 接收到請求後, 將執行以下五道安全與效能防禦流程:

1. 基礎格式檢查:
 - 限制請求方法必須為 POST, 否則回傳 405。
 - 校驗核心欄位 (family_id, admin_uid, target_uid, target_role) 是否齊全, 否則回傳 400。
 - 校驗 target_role 是否屬於枚舉範圍。
 - 管理員自我保護: 嚴禁 admin_uid == target_uid 且 target_role != 'Admin', 防止屋主不小心將自己取消管理員身分。
2. ⚡ I/O 合併校驗 (雙人本地權限查驗):
 - 僅使用一條 SQL: SELECT user_id, role FROM user_families WHERE family_id = %s AND user_id IN (%s, %s), 同時抓取操作者與目標者在該場域的角色。
 - 檢查操作者的角色, 若 role != 'Admin' 則立即中斷並回傳 403。
3. 🔍 全域資安校驗 (目標帳號生死狀態檢查):
 - 查詢全域 users 表: SELECT status FROM users WHERE user_id = %s。
 - 若目標帳號不存在, 回傳 404。
 - 若目標帳號全域狀態 status != 'Active' (例如被系統封鎖), 則拒絕授權, 回傳 403。
4. 🖨️ 冪等 Upsert 數據寫入:

- 分流 **A** (軟撤銷停權): 若 `target_role == 'Revoked'`, 執行 `INSERT ... ON DUPLICATE KEY UPDATE`, 將角色設為 'Revoked', 並強制將 `end_time` 覆蓋設定為 `NOW()`, 關閉所有時效漏洞。
 - 分流 **B** (核發/修改/恢復身份): 執行 Upsert, 直接寫入或覆蓋更新 `role`, `start_time`, `end_time`, `max_uses` 欄位值。
5. 📡 異步實時廣播:
- 通過資料庫事務後, 立即呼叫 `paho.mqtt.publish.single()` 以非阻塞模式向指定主題廣播。

四、回應規範 (Responses)

1. 成功回應 (200 OK / 200 Warning)

- 情境 **A**: 成功核發/更新/恢復身分

```
JSON
HTTP/1.1 200
{
  "status": "Success"
  "msg": "已成功將該使用者身分更新為 Guest。身分異動指令已實時同步至地端閘道器"
```

- 情境 **B**: 成功執行安全性撤銷停權

```
JSON
HTTP/1.1 200
{
  "status": "Success"
  "msg": "已成功撤銷該使用者所有權限 (變更為 Revoked)。身分異動指令已實時同步至地端閘道器"
```

- 情境 **C**: 冪等性防呆警告 (重複撤銷已停權用戶)

```
JSON
HTTP/1.1 200
{
  "status": "Warning"
  "msg": "該使用者權限先前已被撤銷, 無需重複操作"
```

2. 失敗回應 (Error Responses)

- 情境 **A**: 非法越權操作 (操作者不是 Admin) (403 Forbidden)

```
JSON
HTTP/1.1 403
{
  "status": "Error"
  "msg": "權限拒絕: 只有該場域的 Admin 才能管理成員身分"
```

- 情境 B: 目標帳號未在平台註冊 (404 Not Found)

JSON

404

"status" "Error" "msg" "授權失敗: 該目標帳號尚未在平台註冊"



五、MQTT 實時廣播封包規範

當雲端完成資料庫異動時，會向網絡層的 Broker 發射同步封包，供地端閘道器 (Gateway Core) 進行常駐監聽與本地寫入。

- 廣播主題 (Topic): home/security/gateway_{family_id}/auth_sync
- 消息負載 (Payload - JSON):

JSON

{

"event" "MEMBER_ROLE_CHANGED"

"user_data"

"user_id" "target_user_99"

"role" "Guest"

"start_time" "2026-06-04 00:00:00"

"end_time" "2026-06-05 23:59:59"

"max_uses" 3

}



六、cURL 模擬測試情境指令

佈署成功並完成權限清洗 (chmod 755 及 dos2unix) 後，前端或測試工程師可透過以下三組指令模擬真實運行情境：

1. 測試：直接核發「限時、限次數」訪客

Bash

curl -X POST

-H "Content-Type: application/json"

```
curl -X POST -H 'Content-Type: application/json' -d '{"payload": {"family_id": 12, "admin_uid": "admin_001", "target_uid": "target_user_99", "target_role": "Guest", "start_time": "2026-06-04 00:00:00", "end_time": "2026-06-05 23:59:59", "max_uses": 3}}' http://localhost/cgi-bin/update_member_role.py
```

2. 測試：一鍵黑名單停權封鎖（軟撤銷）

```
Bash
curl -X POST -H 'Content-Type: application/json' -d '{"payload": {"family_id": 12, "admin_uid": "admin_001", "target_uid": "target_user_88", "target_role": "Revoked", "start_time": null, "end_time": null, "max_uses": null}}' http://localhost/cgi-bin/update_member_role.py
```

3. 測試：恢復被停權用戶的身分為常駐 Member

```
Bash
curl -X POST -H 'Content-Type: application/json' -d '{"payload": {"family_id": 12, "admin_uid": "admin_001", "target_uid": "target_user_88", "target_role": "Member", "start_time": null, "end_time": null, "max_uses": null}}' http://localhost/cgi-bin/update_member_role.py
```